

AWS re:Invent

NOV. 28 – DEC. 2, 2022 | LAS VEGAS, NV

SEC319

Prevent unintended access with AWS IAM Access Analyzer policy validation

Katie Williams (she/her)

Senior Solutions Architect
AWS

Jeremiah Dunham (he/him)

Senior Software Development Manager
AWS



Agenda

The lifecycle of an IAM policy

AWS Identity and Access Management Access Analyzer overview

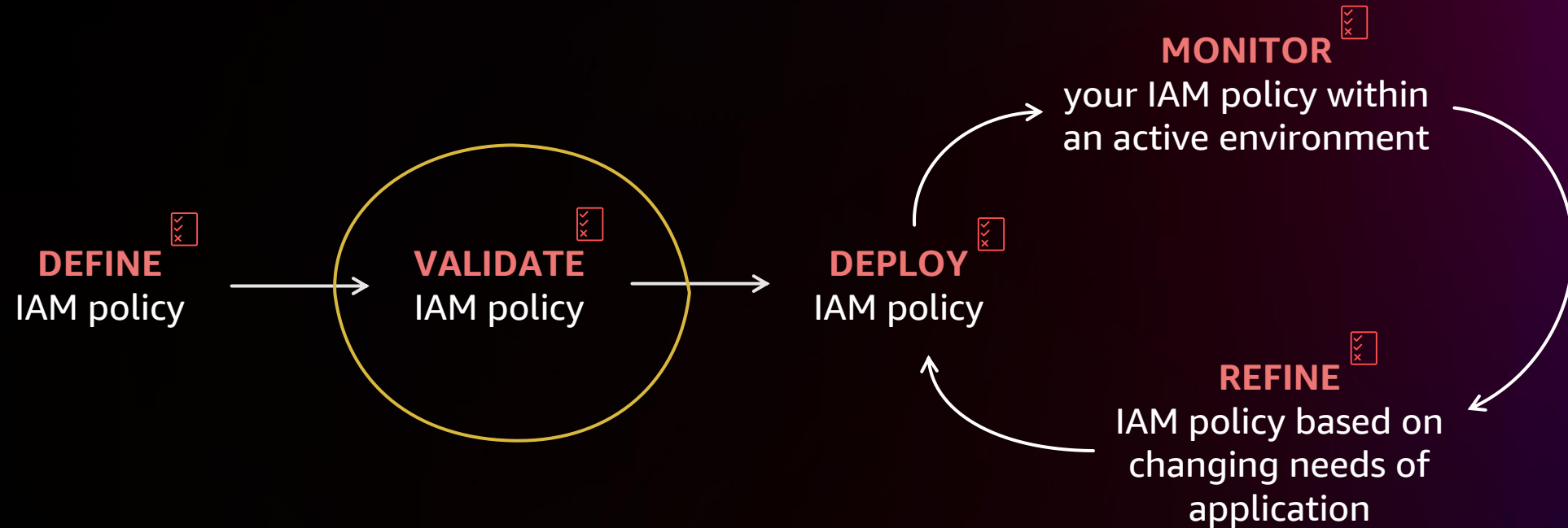
Implementation options

Open discussion

The lifecycle of an IAM policy



AWS Identity and
Access Management
(IAM)



Why automate IAM policy validation?



BUILDERS

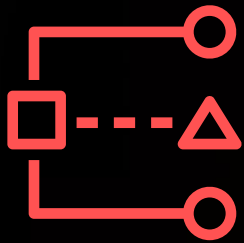
Free builders to
experiment and innovate
quickly – and safely



SECURITY TEAM

Free security people to
focus on high-value tasks
that improve the business

AWS IAM Access Analyzer

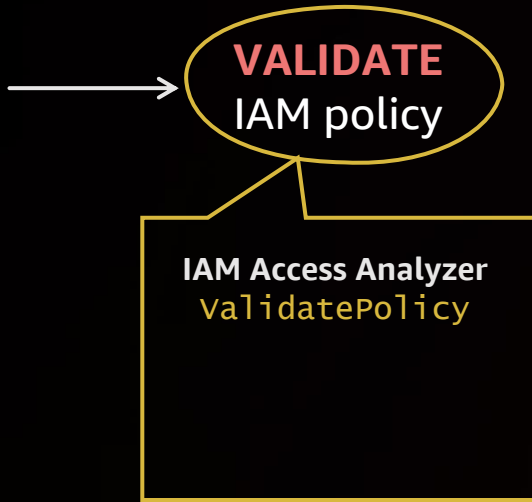


IAM Access
Analyzer

- **Identify resources** in your organization and accounts that are **shared with an external entity** . . . and **preview these external access findings** before deploying new resource permissions
- **Validate IAM policies** against policy grammar and best practices
- **Generate IAM policies** based on access activity in your AWS CloudTrail logs

IAM Access Analyzer APIs

DEFINE
IAM policy



validatePolicy

Generate actionable findings on a policy

- Overly permissive policies

Security Warning: Pass role with star in action and resource:

- Syntax errors

Error: Missing Action

- Policies that don't conform to best practices (nonsecurity)

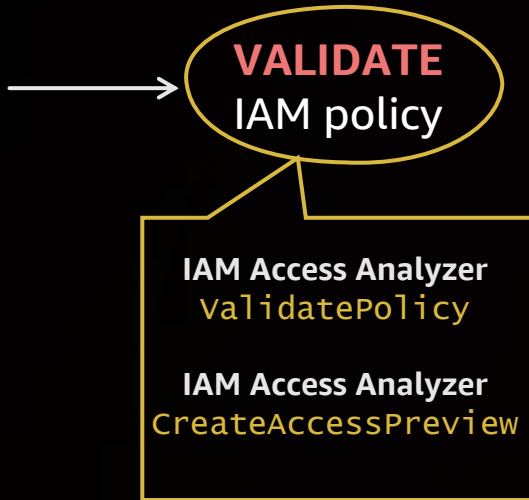
General Warning: Invalid date value

- Recommendations for stylistic improvements

Suggestion: Empty array condition ForAllValues

IAM Access Analyzer APIs

DEFINE
IAM policy



CreateAccessPreview

Preview public or cross-account access granted by new or updated permission policies on any of the following resources:



Amazon S3
bucket



AWS KMS
key



IAM
role



Amazon SQS
queue



AWS Secrets Manager
secret

*Requires an existing, active account analyzer

EXAMPLE:

Amazon SQS
queue policy

→

IAM Access Analyzer
`CreateAccessPreview`



seconds

→

IAM Access Analyzer
`ListAccessPreviewFindings`

1. Policy provides access to a principal **outside of zone of trust**?
 - If yes, who is getting access?
2. Policy makes the resource **public**?

Let's add policy validation to our pipeline



The IAM policy validation trail

IMPLEMENTING POLICY VALIDATION



You may

1. Define **policies** as **JSON documents** in a separate directory and validate them using a **CI/CD pipeline**
2. Define your **policies** using **infrastructure as code** and validate them using a **CI/CD pipeline**
3. Define your **policies** using **infrastructure as code** and validate them using a **CloudFormation hook**

– a thief stole your pipeline in the middle of the night!

What is your choice? ____



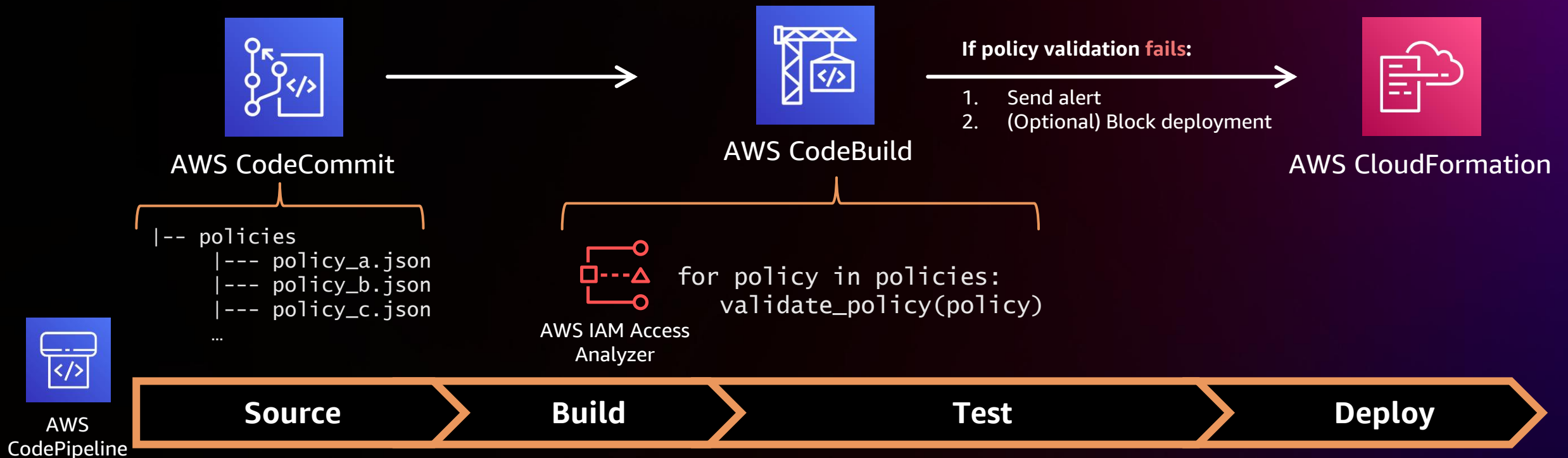
Storing policies as separate JSON documents

IMPLEMENTING POLICY VALIDATION

What is your choice?

1

Define **policies** as **JSON documents** in a separate directory and validate them using a **CI/CD pipeline**

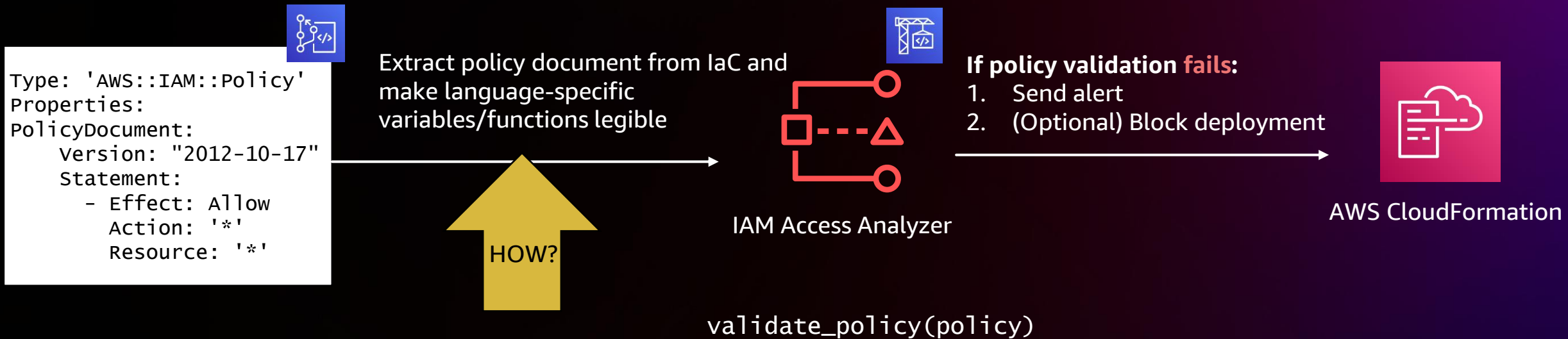


Defining policies with infrastructure as code

IMPLEMENTING POLICY VALIDATION

What is your choice? 2

Define your **policies** using **infrastructure as code** and validate them using a **CI/CD pipeline**



For AWS CloudFormation: cfn-policy-validator

POLICY VALIDATION: DEFINING POLICIES AS INFRASTRUCTURE AS CODE

cfn-policy-validator extracts policy document, replaces intrinsic functions and pseudo parameters with legible inputs, and then runs IAM Access Analyzer `ValidatePolicy` and `CreateAccessPreview` APIs on your policy

```
{
  "Resources": {
    "MyQueue": {
      "Type": "AWS::SQS::Queue"
    },
    "MyQueuePolicy": {
      "Type": "AWS::SQS::QueuePolicy",
      "Properties": {
        "PolicyDocument": {
          "Version": "2012-10-17",
          "Statement": [{
            "Action": "sqs:SendMessage",
            "Effect": "Allow",
            "Resource": {
              "Fn::GetAtt": ["MyQueue", "Arn"]
            },
            "Principal": "*"
          }]
        }
      }
    },
    "Queues": [{ "Ref": "MyQueue" }]
  }
}
```

cfn-policy-validator validate

`"Fn::GetAtt": ["MyQueue", "Arn"]` → **arn:aws:sqs:1111111111:myqueue**



For Terraform: terraform-iam-policy-validator

POLICY VALIDATION: DEFINING POLICIES AS INFRASTRUCTURE AS CODE

terraform-iam-policy-validator extracts IAM identity-based and resource-based policies and then runs IAM Access Analyzer validatePolicy API on your policy

Tool does not support computed resources, such as jsonencode

```
data "aws_iam_policy_document" "demo_policy" {
  statement {
    sid = "PassExecutionRole"
    effect = "Allow"
    actions = ["iam:PassRole"]
    resources = ["arn:aws:iam::123456789012:role/topping-*"]
    condition {
      test = "StringEquals"
      variable = "iam:PassedToService"
      values = ["lambda.amazonaws.com"]
    }
  }
}
```

```
pipenv run python iam_check/iam_check.py
```

→ **arn:aws:iam:1111111111:role/demo-role**

```
resource "aws_iam_policy" "demo_policy" {
  name = "demo-policy"
  description = "This is a demo policy"
  policy = data.aws_iam_policy_document.demo_policy.json
}
```

Resource: <https://github.com/aws-labs/aws-cloudformation-iam-policy-validator>

Open for contribution



Policy validation with a hook

IMPLEMENTING POLICY VALIDATION

What is your choice? 3

Define your **policies** using **infrastructure as code** and validate them using a **CloudFormation hook**

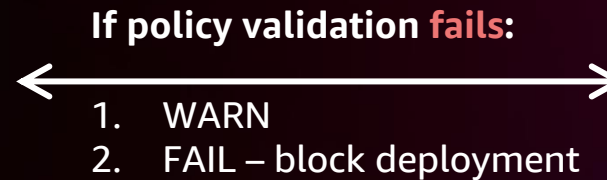
```
...
Type: 'AWS::IAM::Policy'
Properties:
  PolicyDocument:
    Version: "2012-10-17"
    Statement:
      - Effect: Allow
        Action: '*'
        Resource: '*'
...
```



AWS CloudFormation



Resource created/
updated/deleted



**AWS Lambda
CloudFormation hook**

```
cfn-policy-validator validate
--template-path ./my-template.yaml
```

Policy validation in action



Securing **the rest** of the IAM lifecycle

TO BE CONTINUED . . .



"Perform * S3 API
actions on * buckets"

DEFINE
IAM policy

TEST
IAM policy

DEPLOY
IAM policy

MONITOR
your IAM policy within
an active environment

REFINE
IAM policy based on
changing needs of
application

IAM Access Analyzer
Analyzer findings

IAM Access Analyzer
GeneratePolicy

IAM Access Advisor
Service last accessed

IAM Access Analyzer
CreateAccessPreview

IAM Access Analyzer
ValidatePolicy

IAM policy simulator

AWS Partners



Additional resources

- IAM Access Analyzer samples
<https://github.com/aws-samples/aws-iam-access-analyzer-samples>
- IAM Policy Validator for AWS CloudFormation
<https://github.com/awslabs/aws-cloudformation-iam-policy-validator>
- IAM Policy Validator for Terraform (please note the limitations)
<https://github.com/awslabs/terraform-iam-policy-validator>
- Workshop – Integrating AWS IAM Access Analyzer in a CI/CD Pipeline
<https://bit.ly/3SgNf27>
- Workshop – Integrating AWS IAM Access Analyzer in a Jenkins Pipeline
<https://bit.ly/3EVr9iz>

Free MFA security keys in The Village

We're offering **free MFA security keys** at re:Invent as a thank you to attendees

Pick up your key at:

1. The Security, Identity and Compliance kiosk at **The Village, Booth 1335 (in the Venetian)**
2. Cloud Operations Governance, Financial Management, and Observability kiosks at **The Village, Booth 1335 (in the Venetian)**



Thank you!

Jeremiah Dunham
dunham@amazon.com

Katie Williams
wikathr@amazon.com



Please complete the session
survey in the **mobile app**

